Financial Risk Assessment and Micro-Lending System (FRAMS)

Software Testing and Evidence Report

Execution date: 18 October 2026

Revision: bc60c67

Environment: Windows, XAMPP PHP 8.2.12, MariaDB 10.4.32, isolated database frams_capstone_test

Existing database lending_management was not modified.

Summary

Testing Category | Total Executed | Passed | Failed | Blocked | Not Executed

Unit Testing | 45 | 43 | 2 | 0 | 0

Integration Testing | 13 | 13 | 0 | 0 | 0

System Testing | 20 | 20 | 0 | 0 | 0

Security Testing | 17 | 14 | 3 | 0 | 0

Penetration Testing | 8 | 8 | 0 | 0 | 0

PayMongo Testing | 19 | 17 | 0 | 2 | 0

TOTAL | 122 | 115 | 5 | 2 | 0

Pass rate: 95.83% (115 / 120 passed plus failed). Blocked tests are excluded.

Purpose

The tests evaluated the existing PHP FRAMS application: interest and eligibility calculations, login and roles, cash payments, authorization, injection and CSRF checks, and PayMongo QR Ph handling. Application business rules were not edited to obtain passes.

Unit Testing

Executed 45: passed 43, failed 2, blocked 0, not executed 0.

UT-007 FAIL: Zero loan duration. Actual: {"monthly_interest":500,"total_interest":500,"total_payable":10500}

UT-008 FAIL: Negative loan duration. Actual: {"monthly_interest":500,"total_interest":500,"total_payable":10500}

Integration Testing

Executed 13: passed 13, failed 0, blocked 0, not executed 0.

System Testing

Executed 20: passed 20, failed 0, blocked 0, not executed 0.

Security Testing

Executed 17: passed 14, failed 3, blocked 0, not executed 0.

SEC-010 FAIL: Reflected HTML in expense message. Actual: raw HTML reflected

SEC-014 FAIL: Loan status change without CSRF token. Actual: HTTP 200; status Active to Overdue

SEC-016 FAIL: Security response headers. Actual: missing X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, Referrer-Policy

Penetration Testing

Executed 8: passed 8, failed 0, blocked 0, not executed 0.

PayMongo Testing

Executed 19: passed 17, failed 0, blocked 2, not executed 0.

PM-011 BLOCKED: Live PayMongo payment creation. Actual: No request was sent with the live key.

PM-012 BLOCKED: External webhook delivery. Actual: Only local handler calls were executed.

Findings

F-001 (Low) calculateLoanInterestBreakdown

A zero or negative loan term is coerced to one month, so the calculator charges one month of interest instead of rejecting the duration.

Recommendation: Reject a term less than 1 at the calculator and at the application form before interest is stored.

F-002 (Medium) expenses_lending.php message query parameter

The expenses page prints the message query parameter without encoding, so an authenticated user can be sent a link that injects HTML.

Recommendation: Encode $message and $messageType with htmlspecialchars before output. Apply the same fix on the other pages that echo those variables.

F-003 (Medium) loans_lending.php update_status

An authenticated administrator request can change a loan status without a CSRF token.

Recommendation: Call csrfRequireValid() before update_status, as payments_lending.php already does.

F-004 (Low) HTTP response headers

Login responses do not set X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, Referrer-Policy.

Recommendation: Send the missing headers from a shared include used by every page.

F-005 (Low) users_lending.php

With APP_ENV=local, display_errors is on. The user list passes a null email to htmlspecialchars and prints a deprecation warning that includes the application filesystem path.

Recommendation: Pass an empty string when email is null, and set APP_ENV=production with display_errors off on any shared server.

F-006 (High) PayMongo configuration

The project .env sets PAYMONGO_MODE=live and contains a live secret key and live public key. PAYMONGO_WEBHOOK_SECRET is empty. No live API request was sent during this test.

Recommendation: Use test keys and PAYMONGO_MODE=test on this local workstation. Configure the matching webhook secret before accepting QR Ph events. Do not commit .env.

F-007 (Medium) loans_lending.php outstanding statistic

The loans page outstanding figure sums total_payable for loans whose stored status is not Paid. It does not subtract recorded payments. After 10,416.66 in collections the card still showed 17,000.00, while the reports page outstanding was 6,583.34.

Recommendation: Calculate outstanding as total payable minus recorded payments, consistent with calculateLoanBalanceSummary.

Limitations

Live PayMongo payment creation and inbound webhook delivery were blocked. Webhook success and failure results are local simulations. One invalid test key produced a real HTTP 401 from api.paymongo.com and did not post a repayment.

Conclusion

The recorded cases support the implemented interest formula, role checks, and cash payment posting for synthetic data. They also record the failed security and calculation cases listed above. This package does not declare FRAMS fully secure.